

IT PROFESSIONAL PORTFOLIO

Cloud Engineering and Security Projects

PROJECT 45

Enable Resource Control Policies and Attach an S3 Data Perimeter Guardrail

AWS Organizations | Resource Control Policies | Amazon S3 | Prod OU

AUTHOR	Michael Salazar
ENVIRONMENT	Personal AWS Lab
VERSION	v1.0.0
RELEASE DATE	August 3, 2026
STATUS	Complete - Remediation Pending

Executive Summary

Logged into the **AWS Organizations management account**, enabled **Resource Control Policies (RCPs)**, created a customer-managed RCP named **S3 Classified Sensitive**, and attached it directly to the **Prod organizational unit**. The intended control is to deny external access to S3 resources classified as sensitive while allowing access from the organization and AWS services. However, the lab deliberately uses a policy with an unsupported S3 resource-tag condition. In its current form, the policy blocks access and is scheduled to be corrected in a future lab.

CRITICAL WARNING

The lab guide explicitly states that this RCP is intentionally incorrect and should not be used in production. The policy is retained only as a controlled guardrail-failure exercise for future troubleshooting and remediation.

Business Problem

S3 bucket policies can directly expose resources outside an AWS organization. Service Control Policies mainly govern identities and API permissions, but resource-based policies can authorize access through a different evaluation path. RCPs provide an organization-level way to restrict the maximum permissions available to supported resources, even when a local administrator creates an overly permissive bucket policy.

Objectives

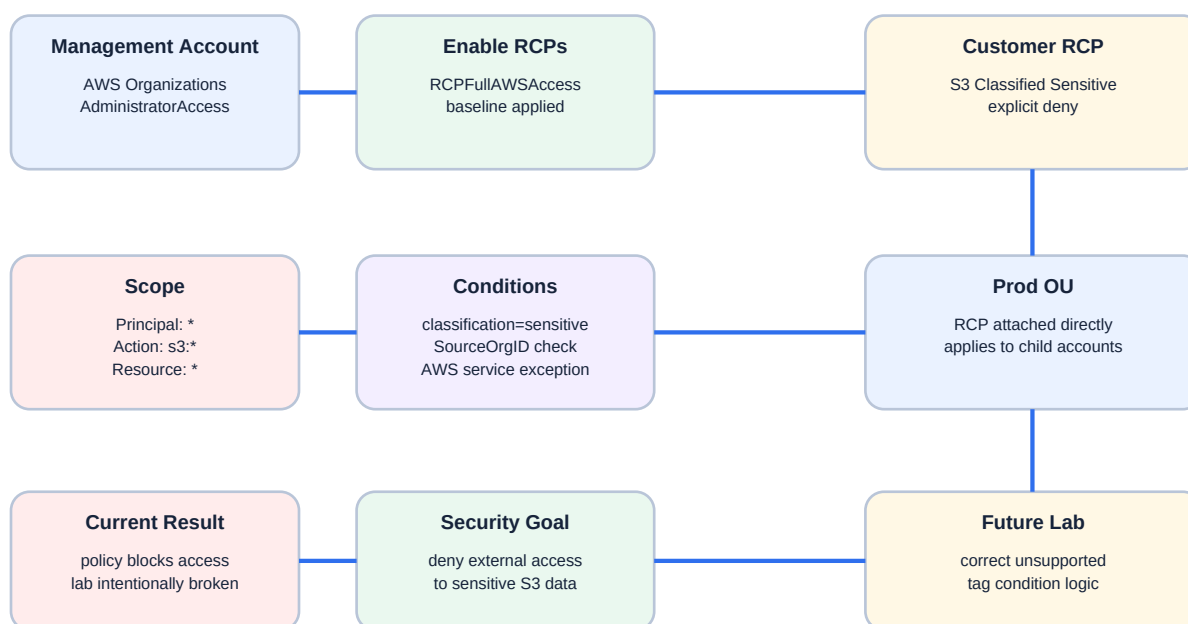
- * Sign into the AWS Organizations management account with AdministratorAccess.
- * Navigate to Organizations policies and enable Resource Control Policies.
- * Confirm the default full-access RCP baseline is present.
- * Create the customer-managed RCP S3 Classified Sensitive.
- * Configure an explicit Deny covering s3:* against all S3 resources.
- * Use organization and AWS-service conditions to express the intended data-perimeter rule.
- * Attach the RCP directly to the Prod OU.
- * Document that the current policy is intentionally broken and denies access until corrected in a later lab.

Environment

Cloud Provider	Amazon Web Services
Administrative Context	AWS Organizations management account / AdministratorAccess
Primary Services	AWS Organizations, Resource Control Policies, Amazon S3
Policy Name	S3 Classified Sensitive

Policy Type	Customer-managed Resource Control Policy
Target	Prod organizational unit
Effect	Explicit Deny
Principal	*
Action	s3:*
Resource	*
Intended Goal	Block external access to S3 resources classified as sensitive
Current Lab Behavior	Policy blocks access; correction intentionally deferred
Status	Lab complete - broken guardrail remediation pending

Architecture



RCPs restrict maximum resource permissions; they do not grant access.

Figure 1 - Organization-level S3 RCP applied to the Prod OU.

Implementation Summary

1. Logged into the AWS Organizations management account.
2. Opened AWS Organizations and navigated to Policies.

3. Enabled Resource Control Policies.
4. Confirmed AWS created the full-access baseline policy used to prevent an immediate organization-wide implicit deny.
5. Created a new customer-managed RCP named S3 Classified Sensitive.
6. Added the DenyAccessToSensitiveData statement.
7. Configured Principal *, Action s3:*, and Resource *.
8. Added the classification resource-tag, SourceOrgID, and PrincipalsAWSService conditions.
9. Opened the Workloads hierarchy and selected the Prod OU.
10. Attached S3 Classified Sensitive directly to the Prod OU.
11. Documented that the policy currently denies access and will be repaired in a future lab.

RCP Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAccessToSensitiveData",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:ResourceTag/classification": "sensitive"
        },
        "StringNotEqualsIfExists": {
          "aws:SourceOrgID": "<organization-id>"
        },
        "BoolIfExists": {
          "aws:PrincipalIsAWSService": "false"
        }
      }
    }
  ]
}
```

KNOWN DEFECT

Source-derived defect: the lab guide states that Amazon S3 does not support the bucket-tag condition used here. Because the policy behavior is intentionally incorrect, the project records the failure state rather than presenting the policy as a valid production control.

Policy Behavior

Effect	Deny	Any request matching the statement is blocked.
Principal	*	The statement can apply to any principal.
Action	s3:*	All supported Amazon S3 actions are within scope.

Resource	*	All supported S3 resources under the attached organizational scope are within scope.
Resource tag condition	classification = sensitive	Intended to select sensitive buckets, but the guide identifies this as unsupported for S3 in this policy.
Source organization	StringNotEqualsIfExists aws:SourceOrgID	Intended to deny requests originating outside the organization.
AWS service exception	BoolIfExists aws:PrincipalIsAWSService = false	Intended to avoid blocking supported AWS service principals.
OU attachment	Prod	Applies the maximum-permission boundary to accounts within the production OU.

Evidence

Figure 2 - S3 Classified Sensitive RCP Created

The screenshot displays the AWS IAM console interface for a Resource Control Policy (RCP) named 'S3 Classified Sensitive'. The 'Policy details' section shows the Name, ARN (redacted), Policy type (Resource control policy (customer managed)), and Description (If a bucket is classified sensitive disallow external access). The 'Content' tab is selected, showing the JSON policy document. The policy document includes a single statement 'DenyAccessToSensitiveData' with an effect of 'Deny', principal of '*', action of 's3:*', resource of '*', and conditions for 'aws:ResourceTag/classification' (sensitive), 'aws:SourceOrgID' (redacted), and 'aws:PrincipalIsAWSService' (false).

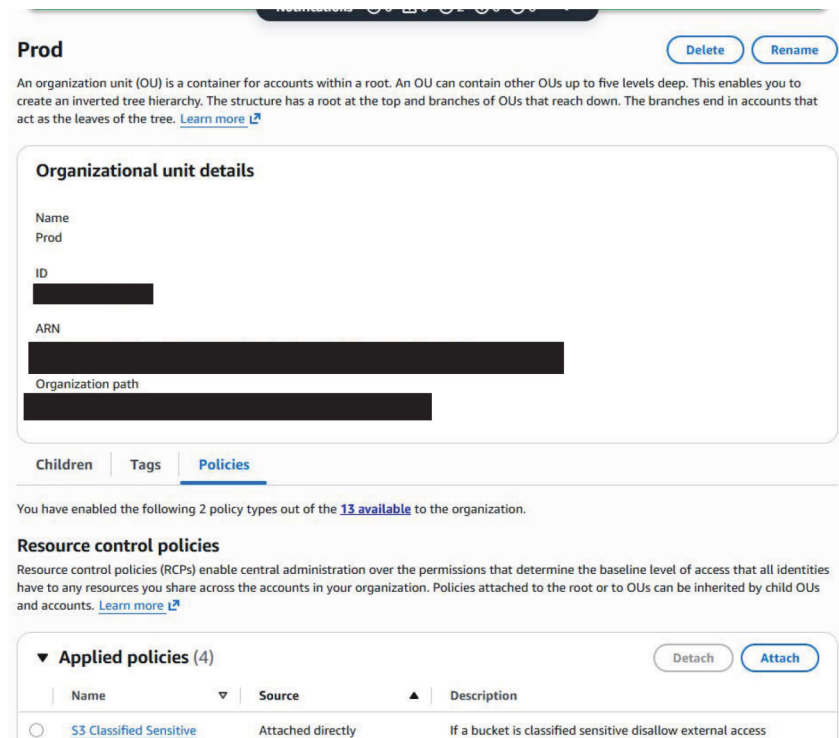
```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Sid": "DenyAccessToSensitiveData",
      "Effect": "Deny",
      "Principal": "*",
      "Action": "s3:*",
      "Resource": "*",
      "Condition": {
        "StringEquals": {
          "aws:ResourceTag/classification": "sensitive"
        },
        "StringNotEqualsIfExists": {
          "aws:SourceOrgID": "redacted"
        },
        "BoolIfExists": {
          "aws:PrincipalIsAWSService": "false"
        }
      }
    }
  ]
}

```

The policy evidence shows the customer-managed RCP named S3 Classified Sensitive. The content includes DenyAccessToSensitiveData with Effect Deny, Principal *, Action s3:*, Resource *, and the classification, SourceOrgID, and PrincipalIsAWSService conditions. The organization identifier is redacted.

Figure 3 - RCP Attached Directly to the Prod OU



The Prod OU evidence shows the Resource control policies section and S3 Classified Sensitive listed as an applied policy with source Attached directly. Organizational identifiers and paths are redacted.

Security Analysis

RCPs define the maximum permissions available to supported resources. They do not grant access; the bucket policy or another resource policy must still provide an allow.

An explicit deny in an RCP can override access granted through a bucket policy or IAM policy, making RCPs useful for organization-wide data-perimeter controls.

RCPs can be attached to an OU so local administrators in child accounts cannot bypass the centralized resource restriction.

The management account is not governed by RCPs in the same way as member accounts, reinforcing the need to minimize management-account workloads.

A defective centralized deny can create a wide production outage. RCP changes require staged testing, exception design, and rollback procedures.

This policy is intentionally unsafe because the lab source identifies the S3 resource-tag condition as unsupported. It should remain a lab-only artifact until corrected.

Lessons Learned

RCPs are organization policies for resource permissions, while SCPs focus on permissions available to identities and accounts.

AWS applies a full-access RCP baseline when the policy type is enabled so existing access is not immediately blocked.

RCPs are evaluated early and can block access that a resource-based policy otherwise allows.

OU targeting allows production controls to be stricter than non-production controls.

Condition-key support must be validated for the target service before deploying a broad explicit deny.

Centralized guardrails can fail safely or fail destructively; testing and rollback planning determine which outcome occurs.

Production Improvements

- * Do not use the current policy outside this controlled lab.
- * Correct the unsupported S3 resource-tag condition in the future remediation lab.
- * Test RCPs in a sandbox OU before attaching them to production.
- * Use a canary account and automated access tests before broad rollout.
- * Maintain an emergency rollback procedure and known-good policy version.
- * Use CloudTrail and EventBridge to alert on RCP creation, update, attachment, and detachment.
- * Require peer review for organization-level explicit-deny policies.
- * Document supported condition keys and service limitations in the policy repository.

Skills Demonstrated

Resource Control Policies	OU targeting	Explicit deny analysis
Amazon S3 guardrails	SourceOrgID conditions	Unsupported condition identification
Centralized enforcement	Production risk management	Future remediation planning

Resume Bullet

RESUME	Enabled AWS Organizations Resource Control Policies, created and attached an S3 data-perimeter RCP to the Prod OU, and documented an intentionally broken explicit-deny condition to demonstrate centralized guardrail risk, service condition-key validation, and production remediation planning.
--------	---

STAR Interview Story

Situation: Public S3 ACL and bucket-policy labs demonstrated how member-account administrators can expose data through local resource configuration.

Task: Create an organization-level resource guardrail intended to prevent external access to sensitive production S3 data.

Action: I enabled RCPs in the management account, created S3 Classified Sensitive, added the organization and AWS-service conditions, attached it directly to the Prod OU, and documented that the unsupported S3 tag condition causes the current policy to block access.

Result: The lab established the RCP control point and produced a controlled failure state that will be corrected in a future lab, demonstrating both the power and operational risk of centralized explicit-deny policies.

Version History

v1.0.0	August 3, 2026	Initial documentation. Enabled RCPs, created S3 Classified Sensitive, attached it directly to the Prod OU, embedded policy and OU evidence, and documented the deliberately broken access-blocking behavior and future remediation requirement.

References

- * Cloud Security Lab a Week - Master the S3 Perimeter with Resource Control Policies.
- * User-provided S3 Classified Sensitive RCP evidence.
- * User-provided Prod OU policy attachment evidence.
- * Project 44 - Expose an S3 Bucket with a Misconfigured Bucket Policy.